

T2.1.B · Action Center dashboard + endpoints HTTP

Owner: Celestino · Branch `pr/t2.1.b-action-center-dashboard` · base `main@daf3bf1` · hace visible y usable T2.1.A en el dashboard sin ejecutar acciones externas reales

Status: PR listo para revisión. **787/787** pytest · **28/28** vitest · **tsc 0 errores** · **build 17/17** · **lint 0 errors**.
Backend: 12 endpoints HTTP nuevos (admin + internal). Landing: 5 route handlers + bridge HMAC + componente UI con 8 estados visuales. **Sin merge** · **sin deploy**.

1. Resumen ejecutivo

T2.1.B conecta el Automation Core (T2.1.A) al dashboard. El usuario premium ahora ve **oportunidades detectadas + acciones recomendadas con riesgo, costo, estado y razón**. Puede *generar acciones, aprobar, rechazar y ejecutar (dry-run)* · todo respetando los guardrails de T2.1.A: LOW auto · MEDIUM/HIGH requieren aprobación · CRITICAL bloqueado.

- Cero acciones externas reales · todos los ejecutores siguen siendo dry-run de T2.1.A.
- Doble esquema de auth: `/admin/automation/*` con `ADMIN_TOKEN` (uso operativo) e `/internal/automation/*` con HMAC bridge (landing → backend, server-to-server) · `ADMIN_TOKEN` nunca llega al cliente.
- Anti-IDOR: el backend resuelve *telefono* desde *subscription_id* y verifica ownership de la *accion_id*. Un usuario no puede aprobar/ejecutar acciones de otro usuario · test específico lo verifica.
- Sanitización de respuesta: el backend filtra *idempotency_key* (interno), *payload_json* crudo y telefono completo antes de enviar al frontend.

2. Endpoints creados (12 nuevos)

Backend FastAPI · `/admin/automation/*` (ADMIN_TOKEN)

Método	Path	Función
GET	<code>/admin/automation/oportunidades?telefono=...</code>	Lista oportunidades detectadas para un telefono
GET	<code>/admin/automation/acciones?telefono=...&estado=...</code>	Lista acciones (filtrable por estado)
POST	<code>/admin/automation/acciones/generar</code>	Body: {telefono} · genera 1 acción por paso de cada playbook sugerido por
POST	<code>/admin/automation/acciones/{id}/aprobar</code>	Cambia needs_approval → approved
POST	<code>/admin/automation/acciones/{id}/rechazar</code>	Cambia → rejected
POST	<code>/admin/automation/acciones/{id}/ejecutar</code>	Ejecuta dry-run · respeta guardrails T2.1.A

Backend FastAPI · `/internal/automation/*` (HMAC bridge)

Método	Path	Body request
POST	<code>/internal/automation/oportunidades</code>	{subscription_id}
POST	<code>/internal/automation/acciones</code>	{subscription_id, estado?}
POST	<code>/internal/automation/acciones/generar</code>	{subscription_id}
POST	<code>/internal/automation/acciones/aprobar</code>	{subscription_id, accion_id}

POST	/internal/automation/acciones/rechazar	{subscription_id, accion_id}
POST	/internal/automation/acciones/ejecutar	{subscription_id, accion_id}

Auth: header *X-Internal-Signature* = HMAC-SHA256(body, INTERNAL_BRIDGE_SECRET). Mismo patrón que */internal/usuario-resumen* (T1.4.D). El backend resuelve *telefono* desde *subscription_id* · NUNCA acepta *telefono* ni *accion_id* sin verificar ownership.

Landing Next · /api/automation/* (auth() server-side)

Método	Path	Función
GET	/api/automation/acciones	Lista del usuario autenticado · query <i><i>estado</i></i> opcional
POST	/api/automation/acciones/generar	Genera desde Opportunity Engine
POST	/api/automation/acciones/[id]/aprobar	—
POST	/api/automation/acciones/[id]/rechazar	—
POST	/api/automation/acciones/[id]/ejecutar	Dry-run · respeta guardrails

3. Componentes UI

Archivo	Tipo	Resumen
landing/lib/automation-types.ts	NEW	Tipos compartidos client+server · <code><i>AccionAutomatizacion</i></code> , <code><i>Estado</i></code>
landing/lib/automation-bridge.ts	NEW	<code><i>server-only</i></code> · 6 funciones HMAC + manejo de timeout/auth/errores. <code><i>bridge</i></code>
landing/lib/__mocks__/_server-only.ts	NEW	Stub para vitest · permite testear el bridge en Node
landing/app/api/automation/acciones/route.ts	NEW	GET
landing/app/api/automation/acciones/generar/route.ts	NEW	POST
landing/app/api/automation/acciones/[id]/aprobar/route.ts	NEW	POST
landing/app/api/automation/acciones/[id]/rechazar/route.ts	NEW	POST
landing/app/api/automation/acciones/[id]/ejecutar/route.ts	NEW	POST
landing/app/dashboard/seccion-action-center.tsx	NEW	Componente React del Action Center · 8 estados visuales · iconos lucide · <code><i>SeccionActionCenter</i></code>
landing/app/dashboard/dashboard-client.tsx	MOD	Importa <code><i>SeccionActionCenter</i></code> y lo renderiza después de <code><i>SeccionDashboard</i></code>
landing/vitest.config.ts	MOD	Alias <code><i>server-only</i></code> al mock para tests de bridge

4. Flujo dashboard → proxy → backend → automation core

```
Cliente (browser)
  ■■ React: SeccionActionCenter
    ■■ useEffect → fetch('/api/automation/acciones')
    ■■ click 'Aprobar' → POST '/api/automation/acciones/123/aprobar'

Landing (Vercel · Next route handler · server-only)
  ■■ auth() → session.subscriptionId (T1.4.D guardrail)
  ■■ aprobarAccion(subscriptionId, 123) ← automation-bridge.ts
    ■■ HMAC-SHA256(body, INTERNAL_BRIDGE_SECRET)
    ■■ POST backend/internal/automation/acciones/aprobar
      headers: X-Internal-Signature, X-Request-ID
      body: {subscription_id, accion_id: 123}

Backend (Render · FastAPI)
  ■■ _verificar_firma_interna(body, sig)
  ■■ subscription_id → telefono (suscripcion_stripe)
  ■■ _accion_pertenece_a_telefono(accion_id, telefono)
    ■■ action_center.aprobar_accion(accion_id)
      ■■ permissions.transicion_valida(...)
      ■■ DB UPDATE estado='approved'
      ■■ audit.registrar_evento('action_approved')

Respuesta sanitizada → landing → cliente → re-fetch lista
```

5. Seguridad aplicada

Capa	Mecanismo
Cliente	NextAuth session · <code><i>subscriptionId</i></code> server-side via <code><i>auth()</i></code> . Cliente NUNCA envía <code><i>telefono</i></code> ni <code><i>accion_id</i></code>
Landing → Backend	HMAC-SHA256(body, INTERNAL_BRIDGE_SECRET). Mismo patrón que <code><i>/internal/stripe-event</i></code> y <code><i>/internal/accion</i></code>
Backend ownership	Resuelve <code><i>telefono</i></code> desde <code><i>subscription_id</i></code> · para acciones, verifica que <code><i>row.telefono == telefono</i></code>
Sanitización response	<code><i>_filtrar_accion_para_dashboard</i></code> excluye <code><i>idempotency_key</i></code> , <code><i>payload_json</i></code> crudo, <code><i>telefono</i></code>

Errores	<code><i>error_message</i></code> max 500 chars · sin stack traces · agente sanitizado en <code><i>marcar_fallida</i></code> .
Logs	Bridge logs muestran <code><i>shortId(subscription_id)</i></code> · backend audit log usa <code><i>telefono_short</i></code> (sin completo).
CRITICAL bloqueado	Auncon aprobación, <code><i>execution.ejecutar_accion</i></code> bloquea y emite audit <code><i>action_blocked_critical</i></code> . Test <code>TestEjecutarCriticalBloqueado</code>
HIGH sin ejecutor	Falla con mensaje claro apuntando a T2.1.C. No envía nada.

6. Tests ejecutados y resultado

pytest · 787/787 passing (769 base T2.1.A + 18 nuevos T2.1.B endpoints) · 172s.
vitest · 28/28 passing (15 auth-matcher + 13 automation-bridge) · 417ms.
tsc · 0 errores · build 17/17 · lint 0 errors · 3 warnings preexistentes.

Tests pytest nuevos · tests/test_automation_endpoints.py

Clase	Tests	Cubre
TestAdminAuth	3	Sin token → 403 · token inválido → 403 · valido → 200
TestAdminGenerarAcciones	2	Genera ≥4 acciones desde perfil completo · telefono requerido
TestAdminListarAcciones	1	Filtro por estado funciona
TestAdminAprobarRechazar	3	Aprobar cambia estado · rechazar cambia estado · inexistente → 404
TestAdminEjecutar	1	LOW pending → completed con result_json
TestInternalAuth	4	Sin firma → 401 · firma inválida → 401 · firma OK → 200 · subscription_id inexistente → 404
TestInternalGenerarAprobar	1	Flow completo internal: generar → listar → aprobar
<code>TestInternalIDOR</code>	<code>1</code>	<code>Aprobar accion_id de otro usuario → 404 · anti-IDOR</code>
<code>TestRespuestasNoExponenSensibles</code>	<code>1</code>	<code>Response NO contiene idempotency_key · payload_json · telefono completo</code>
<code>TestEjecutarCriticalBloqueado</code>	<code>1</code>	<code>Critical aprobado → bloqueado · audit action_blocked_critical</code>

Tests vitest nuevos · landing/lib/automation-bridge.test.ts

Grupo	Tests	Cubre
validación inputs	3	Sin sub_id · sin accion_id · accion_id no entero → ok=false
env vars faltantes	2	Sin BACKEND_URL → ok=false · sin INTERNAL_BRIDGE_SECRET → ok=false (sin red)
firma HMAC y respuestas	7	X-Internal-Signature 64 hex · 200 → data · 404/401 → status propagado · accion_id en body · URL completo
seguridad	1	Respuesta NO contiene INTERNAL_BRIDGE_SECRET en serialización ni en error

7. Riesgos

Riesgo	Severidad	Mitigación
ADMIN_TOKEN expuesto vía /admin/automation/acciones/generar	Bajo	Solo el owner conoce ADMIN_TOKEN · landing usa la ruta /internal/* · si alguien lo usa, se le avisa
Race condition aiosqlite en pytest workers	Cero · solo dev	El primer run reportó 1 falla intermitente con 'Event loop is closed' (issue conocido)
Ejecución pesada · si el usuario hace clic 'Ejecutar' en cada acción, las acciones LOW se ejecutan en paralelo	Bajo · UX	Las acciones LOW se ejecutan en paralelo · acciones puras dry-run (esqueletos). No hay rate limit aún
Telefono Sí está en payload_summary del audit log (COPPA · teléfono presionado)	Medio	Señalar presijio · principio de minimización. Audit log queda accesible solo a b
Si el usuario aprueba una acción HIGH, se queda en 'Approved' indefinidamente	Bajo en UX	El componente T2.1.A.5. muestra aviso claro: 'Esta acción es de alto impacto · está aprobada' · se puede cancelar
Backend no rate-limit a /admin/automation/acciones/generar	Bajo	Generar es idempotente · re-llamar no duplica acciones (idempotency_key). Si cr

8. Out of scope · NO entra en T2.1.B

- **Ejecutores reales** (envío WhatsApp, publicación, Stripe writes) · sigue siendo T2.1.C.
- **Reservas/descuento de créditos** · T2.1.D.
- **Pruning del audit log** · futuro PR.
- **Métricas / dashboard de KPIs del Action Center**.
- **Notificaciones** (email/push) cuando una acción cambia de estado.
- **Re-generación inteligente** (LLM-as-judge) que prioriza oportunidades · hoy es determinístico.
- **UX avanzada**: drag-and-drop priorización · markdown renderer del result · vista de calendario · filtros visuales.

9. Siguiente PR recomendado · T2.1.C

T2.1.C · Ejecutores reales con guardrails:

- Conectar LLM (Anthropic Claude) a los ejecutores LOW para que *generar_plan_semanal*, *generar_calendario_contenido*, *generar_idea_oferta* produzcan output de calidad real (no esqueletos).
- Conectar ejecutor real para MEDIUM *preparar_mensaje_** y *borrador_copy_** · sigue siendo dry-run hasta el envío explícito.
- Conectar HIGH *enviar_mensaje_whatsapp* con guardrails extra: TCPA verificado · opt-in del cliente · rate-limit · reembolso si falla.
- **NO desbloquear CRITICAL** en T2.1.C · queda para futuro PR con confirmación reforzada (2FA owner · timer cooldown · etc).
- Reservas de créditos: descontar al iniciar ejecución · reembolsar si falla. Llega T2.1.D.

10. Instrucciones para abrir PR

Campo	Valor
URL	github.com/celestinojbm/Dona-agent/pull/new/ pr/t2.1.b-action-center-dashboard
Título sugerido	feat(automation): Action Center dashboard + endpoints HTTP (T2.1.B)
Base	main
Head	pr/t2.1.b-action-center-dashboard

11. Body markdown del PR (copy-paste)

Resumen

Conecta el Automation Core (T2.1.A) al dashboard. Premium ve oportunidades + acciones recomendadas con riesgo, costo, estado y razón. Puede generar, aprobar, rechazar y ejecutar (dry-run) respetando guardrails: LOW auto · MEDIUM/HIGH requieren aprobación · CRITICAL bloqueado.

Cero acciones externas reales · todos los ejecutores siguen siendo dry-run de T2.1.A.

Cambios

Backend (agent/main.py):

- 6 endpoints /admin/automation/* (ADMIN_TOKEN)
- 6 endpoints /internal/automation/* (HMAC bridge)
- Helpers `_filtrar_accion_para_dashboard` (anti-leak), `_resolver_telefono_desde_subscription`, `_accion_pertenece_a_telefono` (anti-IDOR)
- Generar crea 1 acción por paso del playbook · idempotente

Backend (agent/automation/execution.py):

- Ajuste de orden: marcar `_running` antes del bloqueo CRITICAL para que la transición `running→failed` sea válida según el lifecycle. Tests T2.1.A siguen verdes.

Landing:

- `automation-types.ts` (tipos compartidos)
- `automation-bridge.ts` (server-only · 6 funciones HMAC)
- 5 route handlers en `/api/automation/*`
- `seccion-action-center.tsx` (componente Action Center)
- `dashboard-client.tsx` · render del componente
- `vitest.config.ts` · alias para server-only
- `__mocks__/_server-only.ts` (stub Node)

Tests:

- `tests/test_automation_endpoints.py` · 18 tests pytest cubre admin auth, generar, listar, aprobar, rechazar, ejecutar, internal auth, IDOR, sanitización response, CRITICAL bloqueado
- `landing/lib/automation-bridge.test.ts` · 13 tests vitest cubre validación inputs, env vars, firma HMAC, status propagation, no-leak de secrets

Tests · 787/787 pytest · 28/28 vitest · build verde

- `pytest tests/test_automation_endpoints.py` · 18/18 · 41s
- `pytest suite completa` · 787/787 · 172s
- `npm test (vitest)` · 28/28 · 417ms
- `npx tsc --noEmit` · 0 errores
- `npm run build` · 17/17 pages OK
- `npm run lint` · 0 errors · 3 warnings preexistentes

Seguridad

- `subscription_id` viene SIEMPRE de `auth()` server-side (T1.4.D)
- Backend resuelve telefono y verifica ownership de `accion_id` (anti-IDOR · `TestInternalIDOR`)
- Response sanitizada · sin `idempotency_key` / `payload_json` / telefono completo (`TestRespuestasNoExponenSensibles`)
- HMAC-SHA256 sobre body exacto · mismo patrón que `/internal/usuario-resumen`
- `ADMIN_TOKEN` nunca llega al cliente · landing usa `/internal/*`
- CRITICAL siempre bloqueado · `audit action_blocked_critical` (`TestEjecutarCriticalBloqueado`)

```
- HIGH sin ejecutor T2.1.A → falla con mensaje claro

## Cero writes / efectos externos

- Sin Stripe writes / DB writes prod / env changes / deploys
- Sin envíos reales WhatsApp / email / publicaciones redes
- Sin gasto de créditos reales
- Sin merge a main

## Out of scope

- Ejecutores reales LLM/WhatsApp (T2.1.C)
- Reservas/reembolsos créditos (T2.1.D)
- Métricas dashboard automation
- Notificaciones / re-generación con LLM-as-judge
- Markdown renderer fancy del result_json

## Plan post-merge

1. Render auto-redeploy ~2 min · 12 endpoints HTTP nuevos vivos.
2. Vercel auto-redeploy · landing con nuevos route handlers +
  componente Action Center.
3. Smoke en producción:
  - login dashboard · verificar que aparece sección 'Centro
    de acción'
  - botón 'Generar acciones' · debería listar acciones
  - aprobar una MEDIUM → verificar cambio de estado
  - ejecutar una LOW pending → ver result dry-run
4. (Opcional) test con curl:
  curl -H 'Authorization: Bearer $ADMIN_TOKEN' \
    'https://dona-agent.onrender.com/admin/automation/acciones?
    telefono=$TEL'
```

Branch pushed · sin merge. Espera tu review en GitHub. Yo no mergeo nada hasta tu OK explícito.